

DFIR Study Outline — Full Overview

Exam-style study sheet covering all eight topic areas

Educational / Defensive DFIR Study Notes

LEARNING OBJECTIVES

- Recall the full DFIR topic map and how domains connect
- Map 'how do I prove X?' workflows to artifacts and Event IDs
- Distinguish detection evidence from attacker tradecraft
- Prioritize IR phases: contain first; memory before disk

SCOPE REMINDER

- This material covers detection, artifacts, and incident response only.
- Attacker actions are phrased as 'adversaries may...' then pivot to evidence.
- Tool/command names appear as IOC strings / exam knowledge — not how-to guides.

1. Malware Analysis

Static analysis

- **FLOSS** — recovers decoded / stack / obfuscated strings adversaries try to hide
- **strings hunt** — URL, IP, domain, registry key, file path, mutex (IOC material)
- **PE header** — tools: *file*, *readpe*, *pefile*, *objdump*; compile time often fake; inspect sections, imports, entry point
- **Entropy >7** — often packed/encrypted (heuristic only; not proof)

Dynamic / C2

- Reputation: Hybrid Analysis, VirusTotal (score, AV labels, family, indicators)
- RE: IDA, Ghidra, x64dbg; sandboxes: Any.Run, Hybrid Analysis, Joe Sandbox
- C2 channels to recognize: HTTP, HTTPS, DNS, loopback, named pipe, beaconing patterns

2. Triage & Collection

- **Velociraptor** — collection, hunt, live response, artifact packs
- **KAPE Target** = collect: MFT, Event Logs, Registry, Prefetch, Amcache
- **KAPE Module** = parse: MFTECmd, EvtxECmd, RECcmd

3. Credential Dumping — Detection Only

- LSASS holds NTLM hashes, Kerberos material, tickets, and sometimes cleartext passwords in memory
- SAM dump requires SYSTEM hive for decryption — look for both files as evidence of intent
- Well-known credential-tool module strings (e.g. `sekurlsa: :logonpasswords`) are **IOC hunt strings**, not recipes
- Prove dump: Event **4688** (suspicious Process Command Line), Sysmon **10** (Process Access → `lsass.exe`), presence of `lsass.dmp`, anomalous handle access
- DCSync: Security Event **4662** with replication rights GUIDs; unexpected account; NTDS hashes without interactive DC logon; correlate with **4624** Type 3 for source IP

4. Persistence

- OS: service, scheduled task, Run key, Startup folder, WMI Filter+Consumer+Binding
- Memory-only (reflective DLL / injection) — gone after reboot; disk persistence survives
- Detect: 4698 (task created), 7045 (service installed), Sysmon, Autoruns anomalies, timeline
- Always read: command line, path, creation time, account context

5. Memory Forensics

- Injection clues: RWX permissions, private memory, MZ header in unexpected regions
- Process hollowing: legitimate process name with malicious memory map
- Volatility/MemProcFS: `pslist` vs `psscan` (hidden/exited/DKOM), `pstree`, `cmdline`, `dlllist`, `netscan`, `malfind`
- `malfind`: `PAGE_EXECUTE_READWRITE` + private + MZ; dump suspicious regions for further analysis

6. Data Exfiltration

- Stage → pack (zip/7z/rar/encrypted) → transfer (DNS, rclone, HTTP, cloud)
- MFT via MFTECmd: create/modify/delete/timeline/USN Journal
- Hayabusa: Proc Exec, PowerShell, Service Install, Scheduled Task, Cred Dumping, Sigma
- rclone evidence: `%APPDATA%\rclone\rclone.conf`, 4688 cmdline, Prefetch, destination logs
- DNS tunnel: nslookup bursts, encoded subdomains, Base64/Base32-like labels, same parent domain + process evidence; motive = bypass proxy when DNS is allowed

7. Web Logs

- Apache common/combined fields; IIS W3C — **#Fields order can change**; always parse header
- Filter by URI, status, IP, method, request id, timestamp
- Web shell chain: HTTP request → IIS w3wp.exe → cmd/powershell child
- Trap: HTTP 200 ≠ successful attack; request ≠ execution — correlate with process creation

8. Incident Response (NIST)

- Phases: Preparation → Detection & Analysis → Containment → Eradication → Recovery → Lessons Learned
- **Contain first** once scope is understood enough to act safely
- Seven layers: network, endpoint, user, application, account, evidence, recovery
- Separate **cause** from **damage**; evidence order: memory → logs → disk; maintain chain of custody
- Accounts: disable, reset credentials, review privileges and authentication logs

How Do I Prove X? — Evidence Map

Use this map under exam pressure. Each row is a claim you must support with artifacts, not assumptions.

Claim	Primary evidence	Supporting / correlate
LSASS credential access	Sysmon 10 → lsass.exe; 4688 cmdline (dump-tool patterns / known IOC strings)	lsass.dmp on disk; handle access; parent process tree
DCSync / AD replication abuse	4662 with DS-Replication-Get-Changes(-All) GUIDs; unexpected subject	4624 Type 3 source IP ≠ DC; no interactive DC logon for that account
New scheduled task	Security 4698; Task Scheduler Operational	XML action/cmdline; Autoruns; creation time vs user session
New service	System 7045; services registry	ImagePath; sc.exe / PowerShell 4688; service EXE hash
WMI persistence	WMI Filter + Consumer + Binding; Sysmon 19/20/21 if enabled	wmiprvse.exe children; permanent event subscription
Process injection / hollow	malfind RWX+MZ; pslist≠psscan; odd VAD	dlllist anomalies; parent/child mismatch; netscan C2
rcclone / cloud exfil	4688 rclone cmdline; rclone.conf	Prefetch; network to cloud API; staged archives in MFT
DNS tunneling	DNS logs: bursts, long/encoded labels, same apex	Process making queries; unusual volume vs baseline
Web shell execution	IIS/Apache request + w3wp → cmd/powershell 4688	File on disk (aspx/php); 200 alone is insufficient
Packed malware	Entropy >7 + few imports + overlay	Sandbox behavior; FLOSS decoded strings; VT family

Core Event ID / Tool Cheat Sheet

ID / Tool	Meaning for DFIR
4688	Process creation (enable command-line auditing) — primary execution evidence
Sysmon 1	Process create with hashes, parent, cmdline
Sysmon 10	ProcessAccess — critical for LSASS handle access detection
4662	Directory Service Access — DCSync / AD object ops (needs audit + SACL)
4624	Successful logon — correlate Logon ID with 4662 for DCSync source IP
4698	Scheduled task created
7045	A service was installed on the system
Sysmon 19/20/21	WMI event filter / consumer / binding (if configured)
KAPE + MFTECmd/EvtxECmd/RECmd	Collect then parse MFT, EVTX, Registry at scale
Velociraptor	Hunt + collect + live response across fleet
Hayabusa	EVTX → Sigma / timeline triage (cred dump, PS, service, task)
Autoruns	Enumerate persistence locations; baseline for anomalies

From the labs

CLASSROOM LAB HIGHLIGHTS

- Lab 1: Sandbox dead-drop T1102.001 — 403 proves attempt; DeviceSync agent-*.tmp host IOC.
- Lab 2: Memory-before-disk; 4688 dump cmdline + 4662/4624 DCSync; WMI+task+BITS+Run → one payload.
- Lab 3: malfind RWX+MZ leads; rundll32 DLL; loopback 127.0.0.1:9090; Observed/Inferred/Unresolved.
- Lab 4: Join WAF/IIS on request ID; prove webshell with w3wp→cmd 4688; keep exfil byte counts separate.
- See also 09-lab-takeaways.pdf (consolidated). Lab source packs are not published in the study repo.

QUICK REFERENCE

- Contain early; acquire memory before reboot when possible
- HTTP 200 ≠ web shell success; correlate process creation
- Entropy >7 = hint of packing, not proof of malice
- 4662 alone is noisy — filter replication GUIDs + non-DC subject + 4624 source
- Memory-only persistence vanishes on reboot — document before power-off
- Always: cmdline + path + time + account = four-tuple for every persistence find

Mini Self-Check

Answer these without looking back. Answers are on the next page.

- Q1.** Name two artifacts that help prove LSASS was dumped without relying on antivirus alerts.
- Q2.** Why must you correlate 4662 with 4624 when investigating possible DCSync?
- Q3.** What is the difference between a KAPE Target and a KAPE Module?
- Q4.** Why is HTTP 200 insufficient to prove a web shell executed?
- Q5.** List the NIST IR phases in order and state which action comes first once you can safely act.

Self-Check Answers

A1. Sysmon Event 10 ProcessAccess targeting lsass.exe; Security 4688 with suspicious dump-related command lines; presence of an lsass.dmp (or similar) file; anomalous handle access patterns.

A2. 4662 shows directory object access (including replication rights) but usually not the source IP; 4624 with the same Logon ID (often Type 3) provides the network source — critical to see if it is a non-DC host.

A3. Target = what to collect (MFT, EVTX, Registry, Prefetch, Amcache). Module = how to parse collected data (MFTECmd, EvtxECmd, RECcmd).

A4. A 200 only means the web server returned OK for the request; it does not prove server-side code ran a shell. Prove execution via child processes of w3wp.exe (cmd/powershell) and on-disk web shell files.

A5. Preparation → Detection & Analysis → Containment → Eradication → Recovery → Lessons Learned. Contain first (once scope allows safe action).